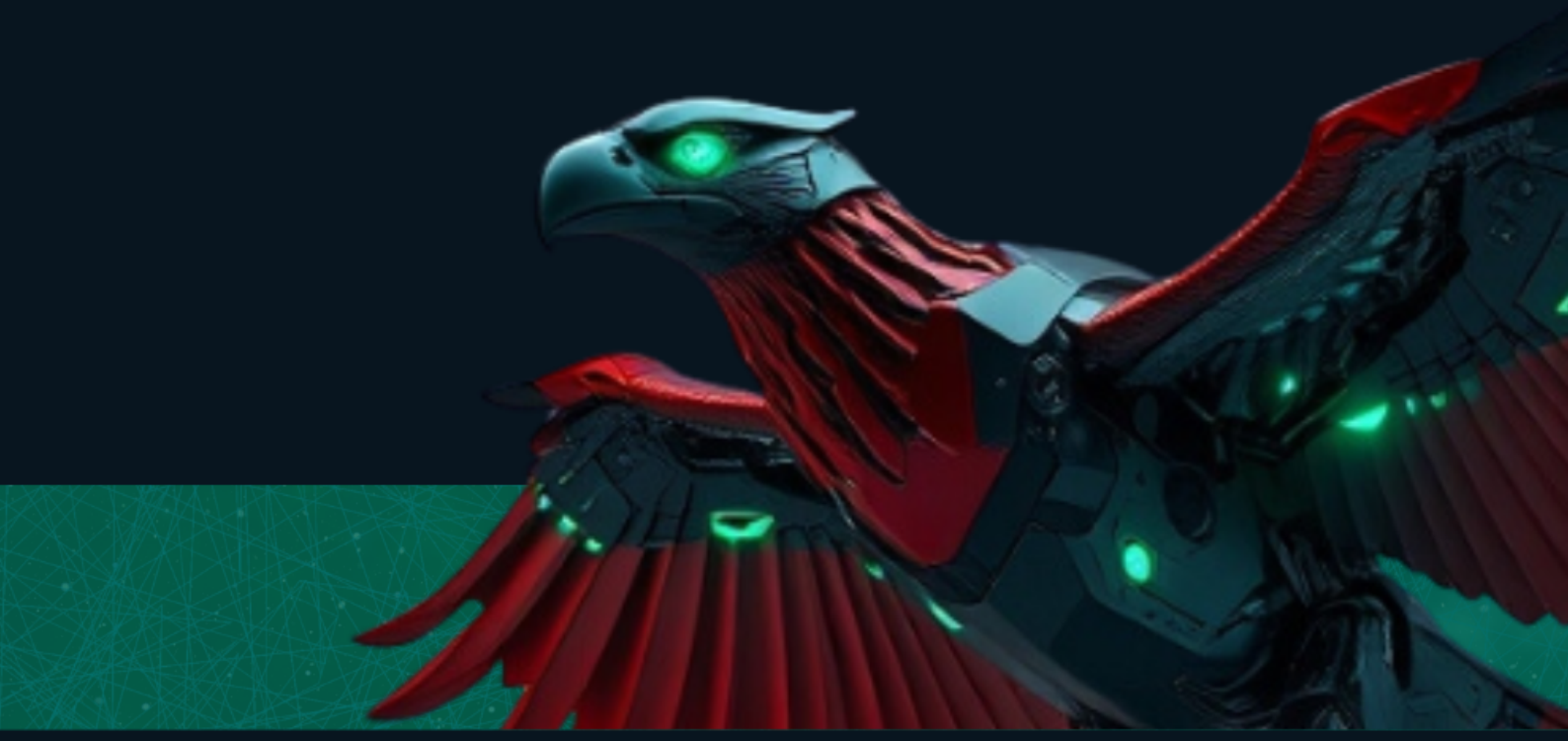
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	CVE-2013-4786
Sub Title	High-severity information disclosure flaw
Status	Closed
Type	Advisory
Severity	High
Source	TheHackerNews.com
Created At	Jul 28, 2026, 04:42 PM

CVE-2013-4786

High-severity information disclosure flaw

Type: ADVISORY • Source: TheHackerNews.com • Created At: Jul 28, 2026, 04:42 PM

Analysis Summary

CVE-2013-4786 is an architectural, high-severity information disclosure vulnerability inherent to the IPMI v2.0 specification (Intelligent Platform Management Interface). Originally defined by Intel, Dell, HP, and NEC, the IPMI protocol is widely implemented in Baseboard Management Controllers (BMCs)- such as Dell iDRAC, HPE iLO, and Supermicro, to enable Out-of-Band (OOB) remote server management. It is heavily utilized across enterprise data centers, cloud hosting providers, and modern AI/GPU computing clusters. The core specification flaw was originally identified during IPMI protocol security research in 2013, with recent exposure investigations by researchers Michael Katchinskiy and Yakir Kadkoda from cybersecurity firm Lava highlighting tens of thousands of internet-exposed instances running UDP port 623.

The flaw exists within the RMCP+ Authenticated Key-Exchange Protocol (RAKP) authentication flow. When an unauthenticated remote attacker initiates an authentication request to an exposed BMC via UDP port 623 specifying any valid username (e.g., ADMIN or root), the BMC responds with an RAKP Message 2 containing an HMAC-SHA1 authentication code derived from that user's password. Because this cryptographic response is sent before authentication is complete, the attacker can capture the hash and perform offline GPU-accelerated brute-force attacks using toolsets like Hashcat. This offline cracking process avoids triggering account lockouts or generating repetitive login failure alerts on the target controller, allowing weak, factory-default, or predictable chassis-sticker passwords to be cracked in minutes.

Exploitation poses a severe, direct risk to critical infrastructure because BMCs operate beneath and completely independent of the host operating system. Controlling a BMC gives an attacker full physical and hardware-level domain over the server- enabling them to manipulate power states, re-flash firmware, deploy persistent rootkits (such as iLOBleed), reinstall host operating systems, or eavesdrop on bare-metal

multi-tenant workloads. Because this compromise occurs at the hardware/firmware tier, traditional EDR agents, host firewalls, and OS-level security tools cannot detect or block the activity. Mitigation relies heavily on network edge controls, including blocking UDP port 623, isolating BMC interfaces on dedicated management VLANs, and rotating default factory credentials immediately upon deployment.

Affected Product

- Dell:
- iDRAC (Integrated Dell Remote Access Controller)—including iDRAC6, iDRAC7, iDRAC8, and iDRAC9 platforms where IPMI over LAN is enabled.
- Dell PowerSwitch S-Series BMC controllers and Virtual Edge Platforms (VEP).
- HPE (Hewlett Packard Enterprise):
- iLO (Integrated Lights-Out)—including iLO 2, iLO 3, iLO 4 (Gen8 / Gen9 servers), and iLO 5 (Gen10 / Synergy compute modules) when IPMI over LAN is enabled.
- HPE Superdome Flex Chassis management RMCs.
- Supermicro:
- Supermicro BMC/IPMI controllers across X8, X9, X10, X11, X12, and modern AI/GPU multi-node motherboard architectures.
- Lenovo / IBM:
- IMM / IMM2 (Integrated Management Module) on IBM System x and Lenovo System x systems.
- XClarity Controller (XCC) on Lenovo ThinkSystem servers.
- ASUS / ASRock Rack / Gigabyte:
- Server platforms utilizing ASPEED AST-series BMC microcontrollers (e.g., AST2400, AST2500, AST2600 running standard IPMI firmware stacks).
- Intel:
- Intel Server Boards running integrated BMC firmware with IPMI over LAN functionality.

Impact

- Unfiltered Hardware-Level Access: Attackers gain direct Out-of-Band (OOB) control over physical servers, allowing them to power-cycle hosts, re-flash system firmware, or modify BIOS configurations completely independent of the operating system.
- Complete EDR & Security Tool Bypass: Because BMCs operate below the operating system layer, traditional Endpoint Detection and Response (EDR) agents, host firewalls, and antivirus software cannot monitor, detect, or block malicious activities executed at this level.
- Persistent Malware & Rootkits: Attackers can install persistent hardware-level malware or rootkits (such as iLOBleed) directly onto the management controller's firmware, allowing access to survive complete OS reinstalls and hard drive wipes.
- Cross-Tenant & Lateral Exposure: In bare-metal, cloud, or AI computing environments, compromising a single BMC enables attackers to move laterally across shared management VLANs or eavesdrop on neighboring tenant workloads and memory telemetry.
- Ransomware & Destructive Disruption: Threat actors can hold physical infrastructure hostage by re-provisioning servers, corrupting firmware, or wiping operating systems, leading to severe system downtime and operational paralysis.
- Compliance & Regulatory Penalties: Unauthorized exposure of sensitive data, loss of multi-tenant isolation, or breach of critical infrastructure can trigger severe regulatory fines (e.g., GDPR, HIPAA, PCI-DSS) and contractual breaches with enterprise clients.

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2013-4786	Flaw that enables remote attackers to obtain password hashes for valid accounts and conduct offline password guessing attacks	7/27/2026	7.5

Remediation

• Isolate Out-of-Band (OOB) Interfaces: Place all Baseboard Management Controllers (BMCs) and IPMI interfaces on isolated, dedicated management VLANs or air-gapped networks. They should never be directly exposed to the public internet.

• Block Port Access at the Network Perimeter: Filter and block incoming traffic to UDP port 623 at the firewall and network edge to prevent external pre-authentication requests.

• Disable IPMI Over LAN / RMCP+: If remote management over IPMI is not strictly required, disable the IPMI over LAN feature entirely in the BMC/BIOS settings.

• Migrate to Modern Management Protocols: Transition remote management workflows to secure alternatives like Redfish, REST APIs, or vendor-specific web consoles enforcing HTTPS and multi-factor authentication (MFA).

• Enforce Strong, Unique Credentials: Immediately change all default, factory-issued, or chassis-sticker passwords upon server deployment. Enforce long, complex passphrases (16+ characters) to resist offline GPU-accelerated brute-force attacks.

• Restrict Access via Access Control Lists (ACLs): Configure host-level BMC firewall rules or network ACLs to ensure only authorized management jump hosts or administrative IP addresses can communicate with UDP port 623.

• Implement Zero-Trust / VPN Architecture: Require administrators to authenticate through a secure VPN or Zero Trust Network Access (ZTNA) solution before gaining network access to the management VLAN.